

2016-09-20 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Host IP address: **192.168.8.134**

Host MAC address: **00:1a:a0:f3:d9:62** (Dell_f3:d9:62)

Host name: **DESKTOP-CLYDEMAN**

User name: **Roger Clydeman**

Date and time of the activity: **Monday 2016-09-19 at approximately 21:10 UTC**

A brief description of what happened:

On Monday 2016-09-19 at approximately 21:10 UTC, Roger Clydeman infected his personally-owned Windows computer with Locky ransomware. The ransomware infection came from an attachment in a malicious email. The attachment was a Word document with a malicious macro disguised as a purchase order.

Associated email:

Date: **2016-09-19 18:16 UTC**

Subject: Order: **67368249/00 - Your ref.: 45248**

Attachment: **OffOrd_67368249-00-35680-66977.docm**

Associated SHA256 hashes:

File name: **OffOrd_67368249-00-35680-66977.docm**

Description: Word document with a malicious macro

SHA256 hash:

1acf27234fa2ba162aab1b4b2809bf39bfb0fd08e46995269f4fc2214f585248

Analysis:

<https://malwr.com/analysis/NjMxMTYwMTY4NmZiNDhiNGFmYjJkNDNmY2UzNTE5Yjg/>

<https://www.hybrid-analysis.com/sample/1acf27234fa2ba162aab1b4b2809bf39bfb0fd08e46995269f4fc2214f585248?environmentId=100>

File name: **C:\Users\Roger.Clydeman\AppData\Local\Temp\chrendokss.dll**

Description: Locky ransomware installed from the Word document

SHA256 hash:

4e746af98620c5beb3f07909d49050744bcf27963b5ea755212bdf0f3bfd926b

DETAILS

You can find the IP address, MAC address and host name easily enough by browsing through the pcap in Wireshark. Be sure you've set up Wireshark according to my tutorial at <http://malware-traffic-analysis.net/tutorials/wireshark/index.html>.

The information is also available in the very first frame (the initial DHCP request) as shown in the image below:

2016-09-20 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Date/Time	Src	port	Dst	port	Info
2016-09-19 21:07:37	0.0.0.0	68	255.255.255.255	67	DHCP Request - Transaction ID 0xc1b53a63
Frame 1: 365 bytes on wire (2920 bits), 365 bytes captured (2920 bits)					
Ethernet II, Src: Dell_f3:d9:62 (00:1a:a0:f3:d9:62), Dst: Broadcast (ff:ff:ff:ff:ff:ff)					
Internet Protocol Version 4, Src: 0.0.0.0 (0.0.0.0), Dst: 255.255.255.255 (255.255.255.255)					
User Datagram Protocol, Src Port: bootpc (68), Dst Port: bootps (67)					
Bootstrap Protocol (Request)					
Message type: Boot Request (1)					
Hardware type: Ethernet (0x01)					
Hardware address length: 6					
Hops: 0					
Transaction ID: 0xc1b53a63					
Seconds elapsed: 0					
Bootp flags: 0x0000 (Unicast)					
Client IP address: 0.0.0.0 (0.0.0.0)					
Your (client) IP address: 0.0.0.0 (0.0.0.0)					
Next server IP address: 0.0.0.0 (0.0.0.0)					
Relay agent IP address: 0.0.0.0 (0.0.0.0)					
Client MAC address: Dell_f3:d9:62 (00:1a:a0:f3:d9:62)					
Client hardware address padding: 00000000000000000000					
Server host name not given					
Boot file name not given					
Magic cookie: DHCP					
Option: (53) DHCP Message Type (Request)					
Option: (61) Client identifier					
Option: (50) Requested IP Address					
Length: 4					
Requested IP Address: 192.168.8.134 (192.168.8.134)					
Option: (12) Host Name					
Length: 16					
Host Name: DESKTOP-CLYDEMAN					
Option: (81) Client Fully Qualified Domain Name					

Shown above: Info for the first frame on the MAC address, IP address and host name.

The only unusual HTTP request in the traffic is the last one in the pcap.

Filter: http.request					
Expression... Clear Apply Save Filter					
Date/Time	Dst	port	Host	Info	
2016-09-19 21:07:39	23.211.21.184	80	cdn.content.prod.cms.msn.com	GET /singletile/summary/alias/experienceby	
2016-09-19 21:09:02	23.0.206.192	80	go.microsoft.com	POST /fwlink/?LinkID=252669&clcid=0x409 HT	
2016-09-19 21:09:03	52.160.91.170	80	dmd.metaservices.microsoft.com	POST /dms/metadata.svc HTTP/1.1	
2016-09-19 21:09:03	23.0.206.192	80	go.microsoft.com	POST /fwlink/?LinkID=252669&clcid=0x409 HT	
2016-09-19 21:09:03	52.160.91.170	80	dmd.metaservices.microsoft.com	POST /dms/metadata.svc HTTP/1.1	
2016-09-19 21:09:04	23.0.206.192	80	go.microsoft.com	POST /fwlink/?LinkID=252669&clcid=0x409 HT	
2016-09-19 21:09:05	52.160.91.170	80	dmd.metaservices.microsoft.com	POST /dms/metadata.svc HTTP/1.1	
2016-09-19 21:09:05	23.0.206.192	80	go.microsoft.com	POST /fwlink/?LinkID=252669&clcid=0x409 HT	
2016-09-19 21:09:05	52.160.91.170	80	dmd.metaservices.microsoft.com	POST /dms/metadata.svc HTTP/1.1	
2016-09-19 21:09:06	23.0.206.192	80	go.microsoft.com	POST /fwlink/?LinkID=252669&clcid=0x409 HT	
2016-09-19 21:09:06	52.160.91.170	80	dmd.metaservices.microsoft.com	POST /dms/metadata.svc HTTP/1.1	
2016-09-19 21:09:07	23.0.206.192	80	go.microsoft.com	POST /fwlink/?LinkID=252669&clcid=0x409 HT	
2016-09-19 21:09:07	52.160.91.170	80	dmd.metaservices.microsoft.com	POST /dms/metadata.svc HTTP/1.1	
2016-09-19 21:10:01	209.200.244.79	80	fungasoap.net	GET /67SELbosjc358 HTTP/1.1	

Shown above: The last HTTP request in the pcap.

2016-09-20 TRAFFIC ANALYSIS EXERCISE - ANSWERS

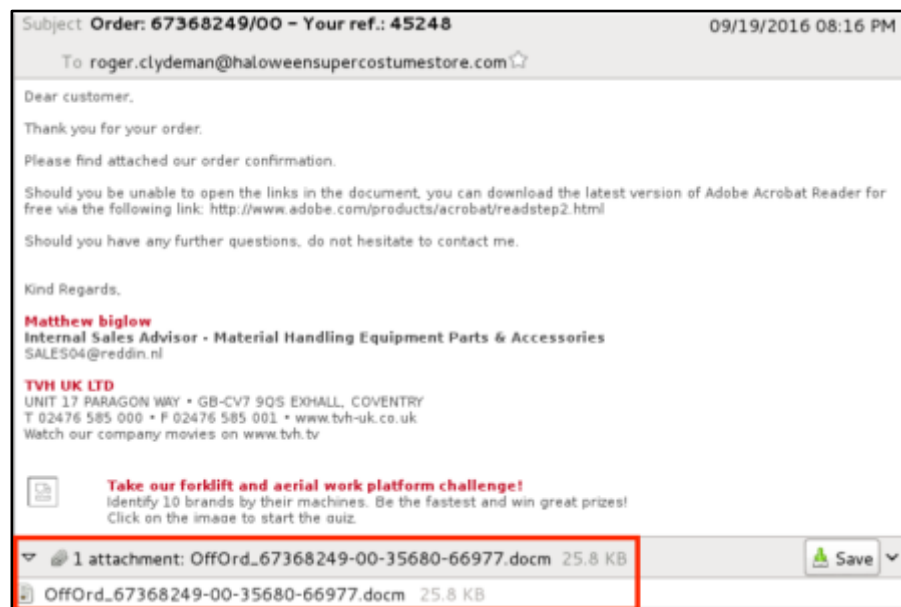
You will also find traffic to an unusual tor-related address as seen in the image below. For details on how to get the HTTPS server names to show up in Wireshark, see the following link at: <http://malware-traffic-analysis.net/tutorials/wireshark/index2.html>

Filter: ssl.handshake.extensions_server_name Expression... Clear Apply Save Filter					
Date/Time	Dst	port	Server Name	Info	
2016-09-19 21:07:42	64.4.54.254	443	v10.vortex-win.data.microsoft.com	Client Hello	
2016-09-19 21:07:43	64.4.54.254	443	v10.vortex-win.data.microsoft.com	Client Hello	
2016-09-19 21:08:00	65.55.252.93	443	sqm.telemetry.microsoft.com	Client Hello	
2016-09-19 21:08:01	65.55.252.93	443	sqm.telemetry.microsoft.com	Client Hello	
2016-09-19 21:08:02	65.55.252.93	443	sqm.telemetry.microsoft.com	Client Hello	
2016-09-19 21:08:03	65.55.252.93	443	sqm.telemetry.microsoft.com	Client Hello	
2016-09-19 21:09:56	104.43.140.223	443	nexus.officeapps.live.com	Client Hello	
2016-09-19 21:10:00	13.76.219.210	443	nexusrules.officeapps.live.com	Client Hello	
2016-09-19 21:10:58	64.4.54.36	443	licensing.mp.microsoft.com	Client Hello	
2016-09-19 21:11:27	72.21.81.200	443	iecvlist.microsoft.com	Client Hello	
2016-09-19 21:11:44	38.229.70.4	443	f5xraa2y2ybtrefz.tor2web.org	Client Hello	
2016-09-19 21:11:44	38.229.70.4	443	f5xraa2y2ybtrefz.tor2web.org	Client Hello	
2016-09-19 21:11:45	38.229.70.4	443	f5xraa2y2ybtrefz.tor2web.org	Client Hello	
2016-09-19 21:11:45	38.229.70.4	443	f5xraa2y2ybtrefz.tor2web.org	Client Hello	
2016-09-19 21:11:45	38.229.70.4	443	f5xraa2y2ybtrefz.tor2web.org	Client Hello	

Shown above: Unusual Tor-related traffic from the pcap.

If you check through the emails, you'll only find one is malicious spam (malspam) that will generate the same type of traffic seen in the pcap.

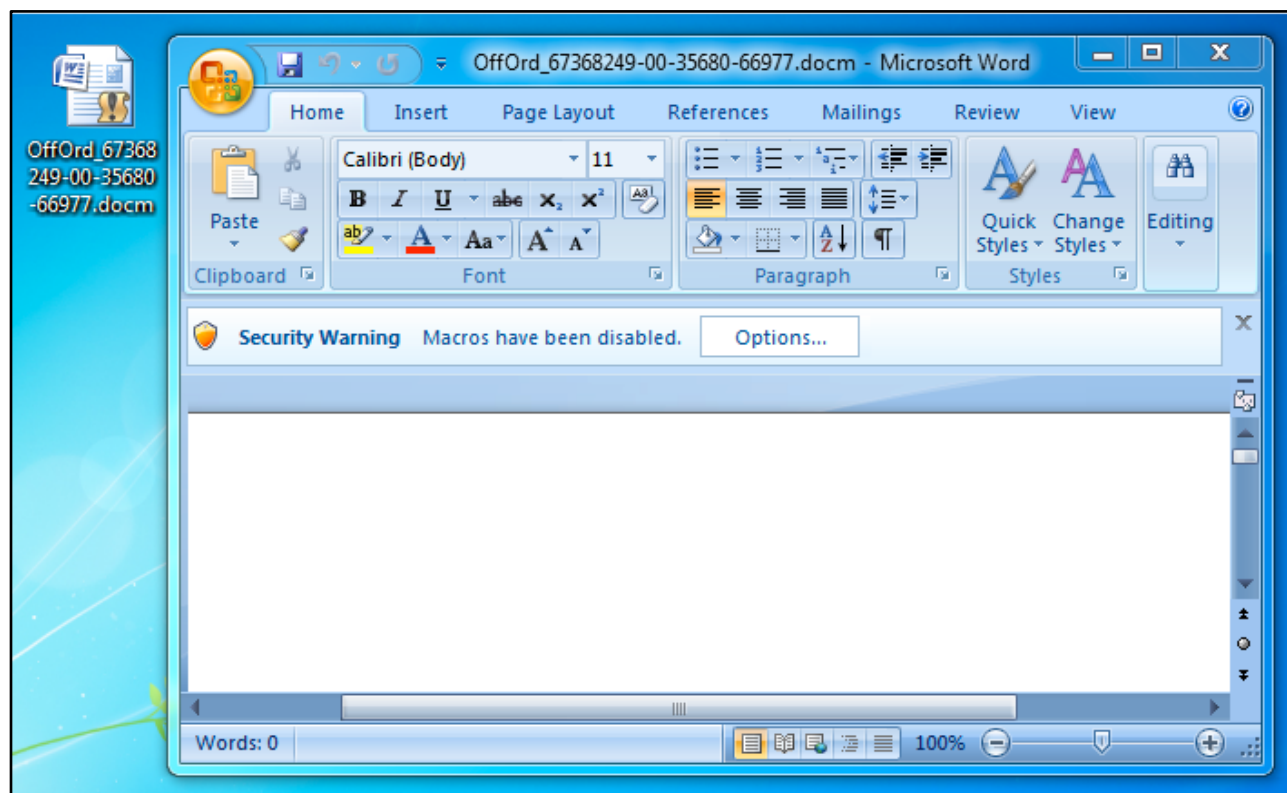
The email at 18:16 UTC has a Word document as an attachment.



Shown above: A malicious Word document.

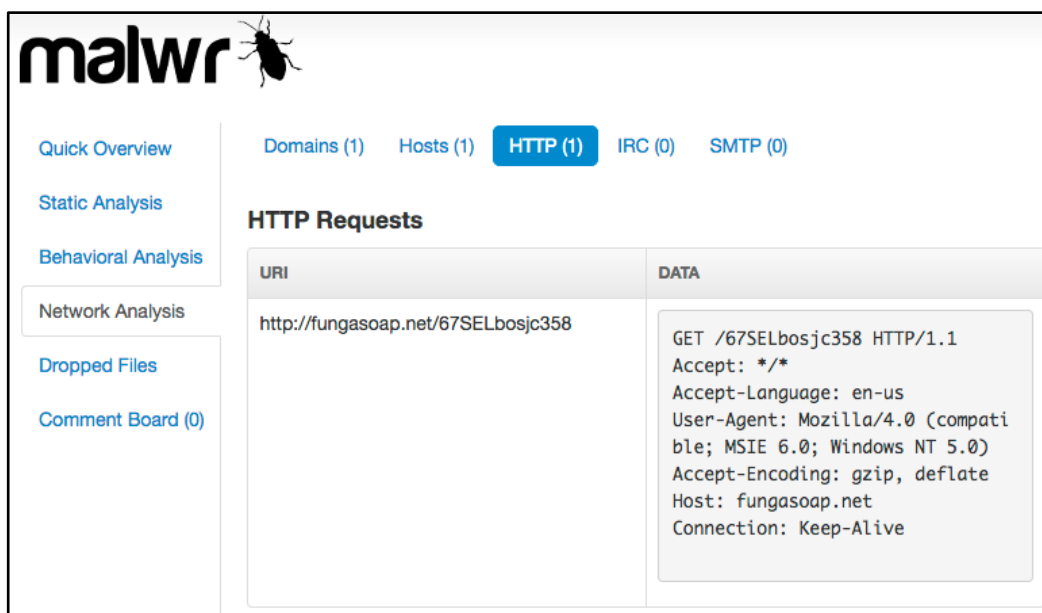
2016-09-20 TRAFFIC ANALYSIS EXERCISE - ANSWERS

The Word document has a macro that, if enabled, will download and install Locky ransomware.



Shown above: The malicious Word document on a host with macros disabled.

This Word document has been submitted to malwr.com and hybrid-analysis.com. Analysis from both shows the same network traffic seen in the exercise pcap.



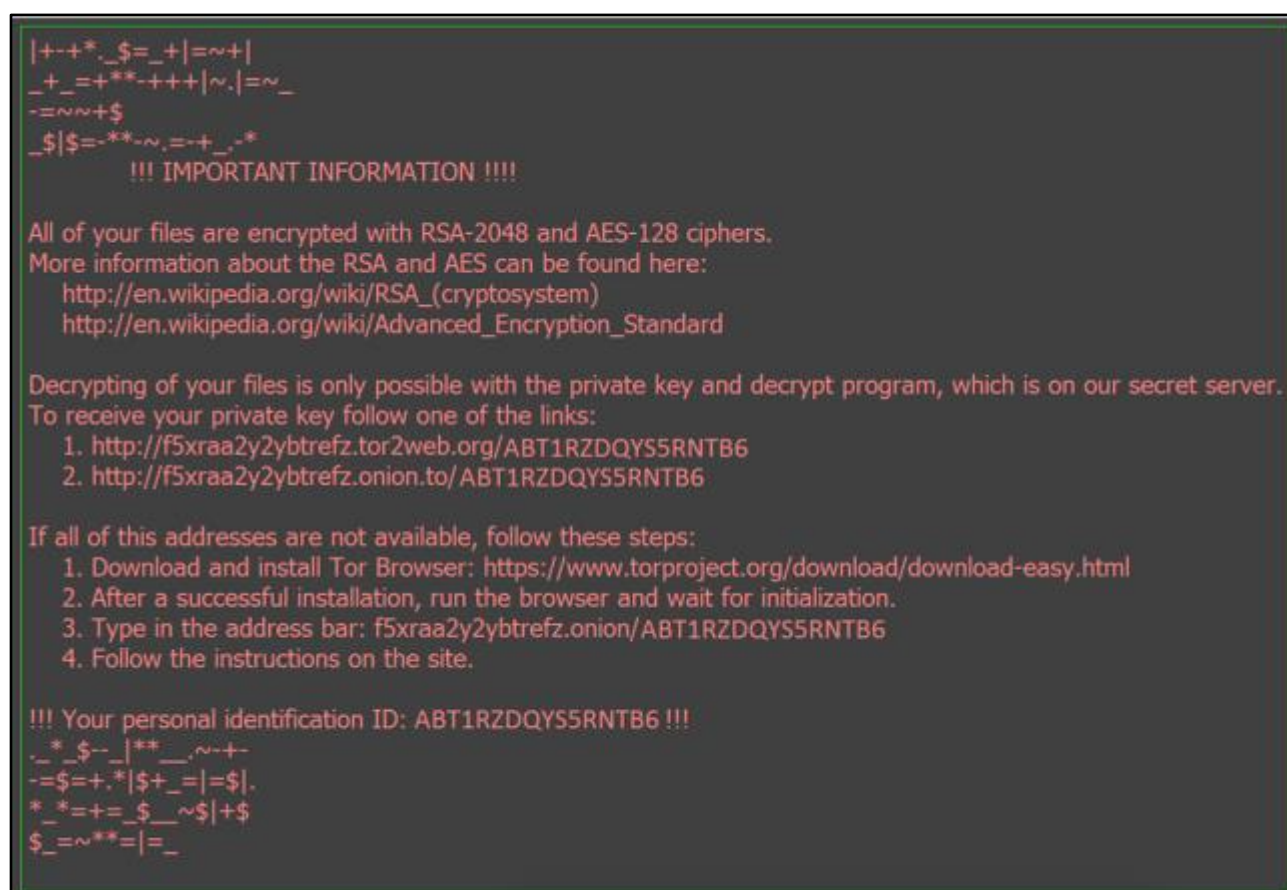
Shown above: Malwr.com shows the same traffic as seen in our pcap.

2016-09-20 TRAFFIC ANALYSIS EXERCISE - ANSWERS

The list of artifacts from the infected host shows items associated with Locky. The .zepto file extension from an artifact from the desktop is the most obvious clue. This file extension has been associated with Locky for a while now.

C:\Users\Roger.Clydeman\AppData\Local\Temp\chrendokss.dll
C:\Users\Roger.Clydeman\AppData\Local\Temp\jugginnh
C:\Users\Roger.Clydeman\Desktop_HELP_instructions.bmp
C:\Users\Roger.Clydeman\Desktop_HELP_instructions.html
C:\Users\Roger.Clydeman\Desktop\OffOrd_67368249-00-35680-66977.docm
C:\Users\Roger.Clydeman\Desktop\ABT1RZDQ-YS5R-NTB6-AC44-B19966C0A74E.zepto

The instructions also are typical for what we've seen from Locky. Below is what the **HELP_instructions.bmp** file looks like in an image viewer:



Shown above: Malwr.com shows the same traffic as seen in our pcap.

The following blogs have also posted articles about the same type of email leading to Locky ransomware:

- <http://blog.dynamoo.com/2016/09/malware-spam-order-2811261000-your-ref.html>
- <https://myonlinesecurity.co.uk/tvh-uk-ltd-random-order-number-malspam-leads-to-locky/>